第 19 章 电子邮件安全

0. 学习目标总览

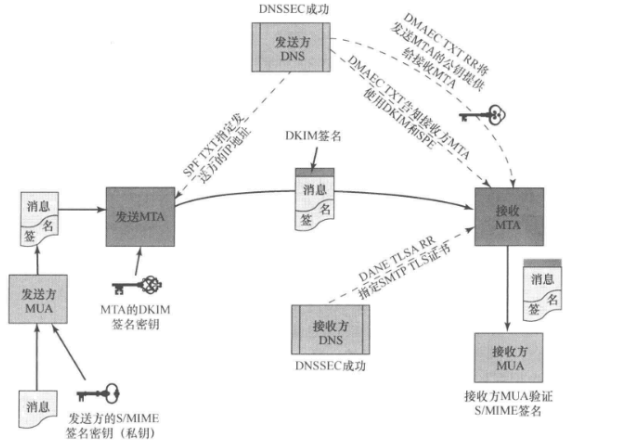
教材给出本章十个学习目标：

1. 小结因特网邮件架构的关键组成。
2. 介绍SMTP、POP3和IMAP的基本功能。
3. 介绍增强日常邮件的MIME的要求。
4. 描述MIME的关键要素。
5. 了解S/MIME的功能及针对它的安全威胁。
6. 了解STARTTLS的基本机制及其在邮件安全中的作用。
7. 了解DANE的基本机制及其在邮件安全中的作用。
8. 了解SPF的基本机制及其在邮件安全中的作用。
9. 了解DKIM的基本机制及其在邮件安全中的作用。
10. 了解DMARC的基本机制及其在邮件安全中的作用。

本章安全体系不是单一协议，而是多个保护层的组合：

```
邮件内容与格式
  |-- RFC 5322：头部 + 正文
  `-- MIME：内容类型 + 传输编码 + 规范格式

邮件安全
  |-- STARTTLS：保护相邻邮件实体之间的 SMTP 传输
  |-- S/MIME：端到端保护消息正文
  |-- DNSSEC / DANE：保护 DNS 数据并约束 TLS 证书
  |-- SPF：认证 SMTP 信封域是否授权发送 IP
  |-- DKIM：认证签名域并保护正文和选定头部
  `-- DMARC：对齐可见 From 域，发布处置策略并接收报告
```



图中，DANE 表示基于 DNS 的命名实体认证；DKIM 表示域名密钥识别的邮件；DMARC 表示基于域的消息认证、报告和一致性协议；DNSSEC 表示域名系统安全扩展；SPF 表示发送方策略框架；S/MIME 表示安全/多用途因特网邮件扩展；TLSA RR 表示传输层安全认证资源记录

图 19.2　保证消息真实性和完整性时，DNSSEC、SPF、DKIM、DMARC、DANE 和 S/MIME 的关系

图 19.2 DNSSEC、SPF、DKIM、DMARC、DANE 和 S/MIME 的协作关系

1. 学习目标 1：因特网邮件架构的关键组成

因特网邮件架构由用户侧的消息用户代理和传输侧的消息处理服务组成。发送方 MUA 格式化消息并提交给 MHS；MHS 经一个或多个 MTA 中继消息，最终通过 MDA 投递到消息存储；接收方 MUA 再检索并显示消息。

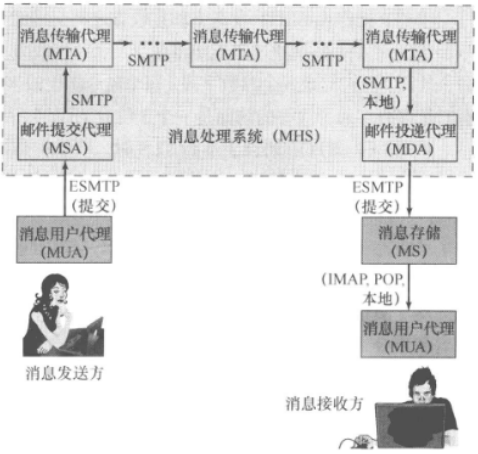


图 19.1　因特网邮件架构的功能模块和标准协议

图 19.1 因特网邮件架构的功能模块和标准协议

组件	全称	主要职责
MUA	消息用户代理	代表用户生成、格式化、提交、接收、存储或显示邮件。
MSA	邮件提交代理	接收 MUA 提交的消息，执行托管域策略和因特网标准要求。
MTA	消息传输代理	在应用层评估路由并中继邮件，直到到达目标 MDA；同时添加路径信息。
MDA	邮件投递代理	将消息从 MHS 投递到消息存储。
MS	消息存储	长期保存邮件，可位于远程服务器，也可与 MUA 同机部署。

行政管理域（ADMD）是执行特定邮件策略和信任决策的邮件提供者，例如企业 IT 部门或 ISP。DNS 提供主机名与地址映射；发送 MTA 查询接收域的 MX 资源记录，以找到下一跳接收 MTA。

```
发送方 MUA
  `-- SUBMISSION/SMTP --> MSA
     `-- SMTP --> 发送 MTA
        `-- SMTP --> 中继 MTA（可有多个）
           `-- SMTP --> 接收 MTA
              `-- MDA --> MS
                 `-- POP3/IMAP --> 接收方 MUA
```

2. 学习目标 2：SMTP、POP3 和 IMAP 的基本功能

2.1 SMTP、ESMTP 与 SUBMISSION

SMTP 是运行在 TCP 上的文本型客户端/服务器协议，负责邮件提交、中继和传输。发送方先建立 TCP 连接，再发送由四字母命令码及可选参数组成的命令；接收方返回以三位数字代码开头的应答。中继 MTA 收到消息后

会转为下一段连接的 SMTP 客户端。

后续 SMTP 修订增加了扩展命令，通常称为 ESMTP。MUA 到 MSA 的首选提交标准是 SUBMISSION：它从 SMTP 演化而来，但使用独立 TCP 端口，并提出访问授权等不同要求。

2.2 POP3 与 IMAP

协议	基本功能	教材给出的常用端口	特点
POP3	用户代理从邮件服务器下载、检索和删除邮件。	TCP 110	认证后使用较简单的命令访问邮件。
IMAP	用户代理访问并管理服务器上的邮件。	TCP 143	认证能力更强，并提供 POP3 不支持的其他功能。

SMTP 解决“如何把邮件送达”，POP3/IMAP 解决“用户如何访问已投递邮件”。这些协议均可在 TLS 上运行，以保护相邻实体之间的通信。

3. 学习目标 3：MIME 的必要性

RFC 5322 定义传统因特网文本邮件格式：消息由若干头部行和正文组成，二者以一个空行分隔。常见头部有 `From`、`To`、`Subject`、`Date` 和唯一的 `Message-ID`。RFC 5322 区分邮件信封与内容，但其内容格式以 ASCII 文本为基础。

原始 SMTP/RFC 5322 方案不能可靠满足现代邮件需求：

1. 不能直接传输可执行文件和其他二进制对象。
2. 不能直接传输用高位字符表示的民族语言文本。
3. 某些 SMTP 服务器会拒绝超长消息。
4. ASCII 与 EBCDIC 网关可能使用不一致的字符映射。
5. SMTP 与 X.400 网关难以处理非文本数据。
6. 不完全合规的实现可能改变回车换行、截断长行、去除尾随空白、填充行或转换制表符。

MIME 是 RFC 5322 框架的拓展，其作用是解决使用 SMTP 或其他邮件传输协议时的一些问题和限制。

MIME 在兼容 RFC 5322 的前提下解决这些问题：它扩展邮件头部，标准化多媒体内容格式，并定义不会轻易被邮件传输系统改写的传输编码。

4. 学习目标 4：MIME 的关键要素

4.1 五个 MIME 头部字段

字段	含义
`MIME-Version`	参数必须为 `1.0`，表明消息遵循 MIME 规范。
`Content-Type`	描述正文的媒体类型、子类型及参数，指导接收代理显示或处理内容。
`Content-Transfer-Encoding`	指明正文为适应邮件传输而采用的表示或转换。
`Content-ID`	在多种场景下唯一标识 MIME 实体。
`Content-Description`	为音频等不可直接阅读的对象提供文本说明。

前三个字段是合适实现必须支持的字段，后两个字段在接收端可以是可选的。

4.2 内容类型

表 19.1 MIME 内容类型

类 型	子 类 型	描 述
text	plain	无格式文本；可以是 ASSCII 码或 ISO 8859
	enriched	提供更大的格式灵活性
multipart	mixed	各部分相互独立但被一起传送。它们应以在邮件消息中出现的顺序显示给接收方
	parallel	除了传送时各部分无序，其余与 mixed 的相同
	alternative	不同部分是同一消息的不同表现形式。它们以增序排列，接收方邮件系统按照最佳方式显示给用户
	Digest	类似于 mixed，但每部分默认的类型/子类型为 message/rfc822
message	rfc822	正文本身是已封装消息，它符合 RFC 822
	partial	允许以对接收方透明的方式分割大邮件
	external-body	包含一个到其他对象的指针
image	jpeg	图像为 JFIF 编码的 JPEG 格式
	gif	图像为 GIF 格式
video	mpeg	MPEG 格式
audio	basic	以 8 kHz 采样率编码的单信道 8 位 ISDN μ 律
application	PostScript	Adobe Postscript 格式
	octet-stream	由 8 位字节组成的普通二进制数据

表 19.1 MIME 内容类型

MIME 的七类基本内容是 `text`、`multipart`、`message`、`image`、`audio`、`video` 和 `application`。其中需要重点掌握：

- `multipart/mixed`：按特定顺序组合多个独立部分；
- `multipart/parallel`：各部分顺序不重要，可在条件允许时并行显示；
- `multipart/alternative`：同一信息的多种表示，按优先级递增排列；
- `multipart/digest`：每个部分都是带头部的 RFC 5322 消息；
- `message/rfc822`：封装一条完整的 RFC 5322 或 MIME 消息；
- `message/partial`：将大消息分片，使用标识、序号和总片数重组；
- `message/external-body`：正文不携带实际对象，只给出外部对象的访问方法；
- `application`：无法归入其他类型的二进制数据或由邮件应用处理的信息。

`multipart` 使用不能出现在任何正文部分中的边界字符串分隔各部分，最后一个边界还带有结束后缀。

4.3 传输编码和规范格式

编码	作用
7bit	数据由较短的 ASCII 文本行组成。
8bit	允许高位置位的非 ASCII 字节，但行仍较短。
binary	允许任意字节，行长也不必适合 SMTP。
quoted-printable	用十六进制表示不安全字符，适合主要由可打印文本构成的数据。
base64	将每 3 字节输入映射为 4 个可打印 ASCII 字符，适合二进制数据。
x-token	厂商或应用专用的非标准编码。

`7bit`、`8bit` 和 `binary` 主要描述数据性质；真正定义转换的常用方案是 `quoted-printable` 和 `base64`。规范格式则把系统本地字符集、换行约定、记录长度和文件属性等转换为跨系统一致、适合特定媒体类型的表示。

5. 学习目标 5：S/MIME 的功能及安全威胁

5.1 邮件威胁与综合防护

邮件威胁可按四个安全目标分类：真实性威胁导致未授权访问或身份伪造；完整性威胁导致内容被修改；保密性威胁导致敏感信息泄露；可用性威胁阻碍正常收发邮件。

典型威胁	主要后果	教材给出的防护方向
未授权 MTA、欺诈域、伪造地址	域信誉受损、垃圾邮件、网络钓鱼和敏感信息泄露	基于域的认证与数字签名。
传输途中篡改或流量监听	内容替换、敏感信息泄露	服务器间 TLS 与端到端邮件保护。
垃圾邮件	用户收到恶意链接或大量无用邮件	反垃圾邮件技术。
DoS/DDoS	企业无法发送或接收邮件	多邮件服务器或云邮件服务。

STARTTLS、S/MIME、DNSSEC、DANE、SPF、DKIM 和 DMARC 分别解决传输、内容、DNS 数据、证书、发送 IP、域签名及策略协同问题，必须组合使用。

5.2 S/MIME 四类基本服务

S/MIME 是 MIME 的安全增强，借助 CMS 对 MIME 实体进行签名、加密、摘要或压缩。教材以 RSA/SHA-256 和 AES-128/CBC 为典型算法。

服务	典型过程	提供的性质
数字签名	对消息计算 SHA-256 摘要，再用发送方 RSA 私钥生成签名。	发送方认证、完整性和不可抵赖性。
消息加密	随机生成一次性内容加密密钥，用 AES-128/CBC 加密消息，再用接收方 RSA 公钥加密内容密钥。	保密性和密钥分发。
压缩	在签名和加密前后按规则压缩消息。	节省传输与存储空间。
邮件兼容性	对二进制安全对象执行 base64 转换。	适配只接受 ASCII 文本的邮件系统。

每条消息使用独立的一次性内容加密密钥，避免用低效的公钥算法直接加密大消息，也适应电子邮件存储转发、不便实时握手的特点。对多个接收方，可分别用每个接收方公钥加密同一内容密钥。

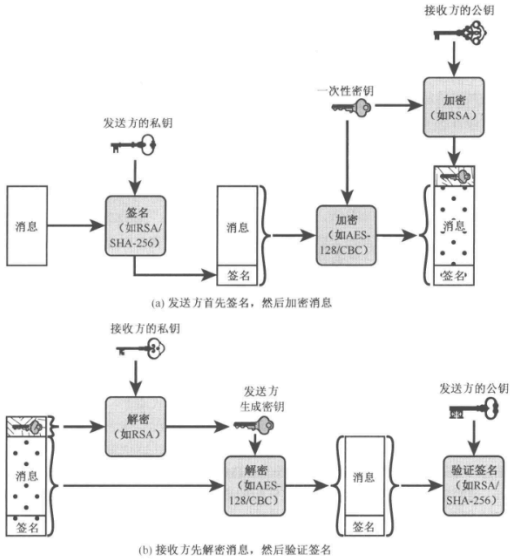


图 19.3　简化的 S/MIME 流程

图 19.3 简化的 S/MIME 签名后加密流程

签名后加密会隐藏签名者身份，并便于保留明文消息的签名；先加密后签名则允许在不读取明文的情况下验证外层签名。若使用有损压缩，应先压缩再签名；不建议压缩二进制加密数据，但可压缩其 base64 表示。

5.3 S/MIME 内容类型与消息处理

CMS 定义四种基础内容类型： `Data` 、 `SignedData` 、 `EnvelopedData` 和 `CompressedData` 。

- **EnvelopedData**：为消息生成会话密钥；用每个接收方 RSA 公钥加密会话密钥；为每个接收方生成 `RecipientInfo` ；用会话密钥加密内容；最后通常执行 base64 编码。
- **SignedData**：计算内容摘要并生成签名； `SignerInfo` 记录证书、摘要算法、签名算法和签名值；对象还可携带构造证书链所需的证书。
- **透明签名**：使用 `multipart/signed` ，第一部分是可直接读取的 MIME 内容，第二部分是分离式签名 `application/pkcs7-signature` ，非 S/MIME 客户端仍能读取正文。
- **注册请求**： `application/pkcs10` 携带证书主题、公钥和对请求信息的签名。
- **仅含证书消息**：携带证书或 CRL，不含消息正文， `SignerInfo` 为空。

所有待保护 MIME 实体都应先转换为适当的规范格式。安全算法产生的二进制对象通常在外层 MIME 中用 base64 编码；透明签名的正文若不是 `7bit` ，则应使用 base64 或 quoted-printable，避免传输改变被签名内容。

5.4 证书与增强服务

S/MIME 使用 X.509v3 证书。用户代理需要生成并安全保护密钥对，向 CA 注册公钥，并维护验证传入签名和加密流出消息所需的本地证书及 CRL。

RFC 2634 定义四种增强服务：签收收据对原消息和原签名再签名，证明接收；安全标签标注敏感性、优先级或角色，用于访问控制；邮件列表代理替发送方针对每个接收方执行专门加密；签名证书属性把发送方证书安全绑定到签名。

S/MIME 的安全依赖正确的密钥生成与私钥保护、可信证书与撤销检查、消息规范化、算法选择和接收方能力协商。任一环节失效，都可能使签名无法验证或使内容无法解密。

6. 学习目标 6：STARTTLS 的机制与作用

STARTTLS 是 SMTP 安全扩展。通信双方先建立普通 SMTP 连接并宣传扩展能力；若双方支持 STARTTLS，则把连接升级为 TLS，之后 SMTP 信封、命令和消息都在 TLS 中传输。类似机制也可用于 POP3 和 IMAP。

STARTTLS 保护的是当前相邻实体之间的链路，例如 MUA—MSA 或 MTA—MTA。邮件经过多个中继时，每一跳需要分别建立 TLS；它不像 S/MIME 那样让保护随消息一直保持到最终 MUA。

机会式 STARTTLS 有两个主要风险：攻击者可破坏 TLS 能力宣传，使连接降级到明文；SMTP 实践中还可能接受自签名或名称不匹配的证书，使服务器认证不可靠。DANE 可用经过 DNSSEC 签名的 TLSA 记录声明必须加密并认证证书，从而补强 STARTTLS。

7. 学习目标 7：DANE 的机制与作用

7.1 DNSSEC 基础

DNS 是由域名空间、分布式资源记录数据库、域名服务器和解析器组成的目录查找服务。邮件系统查询接收域的 MX 记录以定位接收 MTA。

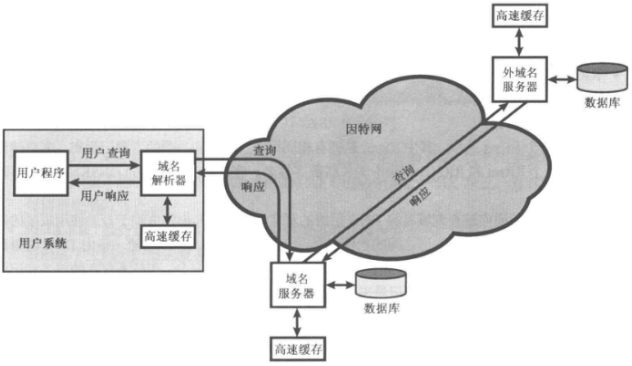


图 19.4 DNS 域名解析

图 19.4 DNS 域名解析过程

DNSSEC 由区管理机构为资源记录集合（RRset）生成数字签名，解析器验证签名，从而提供数据源认证和数据完整性。它不要求信任中间 DNS 服务器或缓存。信任从根区等信任锚开始，经父区验证子区，建立到目标应答区的信任链。

四类新资源记录是：`DNSKEY` 携带公钥，`RRSIG` 携带 RRset 的数字签名，`DS` 连接父区和子区的授权签名者，`NSEC` 对名称或记录不存在的否定应答进行认证。

7.2 DANE 与 TLSA

DANE 使用 DNSSEC 将 X.509 证书或公钥绑定到域名，减少全球 CA 体系中任一受破坏 CA 造成广泛影响的风险。TLSA 记录由四个字段组成：证书用途、选择器、匹配类型和证书相关数据。

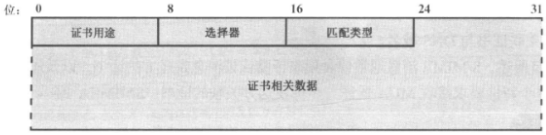


图 19.5 TLSA RR 传输格式

图 19.5 TLSA 资源记录格式

证书用途	作用
PKIX-TA	限制可为服务证书提供保证的 CA，同时要求 PKIX 链验证到客户端可信根。
PKIX-EE	限制服务所用的终端实体证书，同时要求 PKIX 链验证。
DANE-TA	由域管理者指定新的信任锚，可使用域自己的 CA。
DANE-EE	直接信任域颁发的服务证书，不依赖第三方 CA 根。

选择器决定匹配完整证书还是公钥；**匹配类型**可为精确匹配、SHA-256 哈希或 SHA-512 哈希。对于 SMTP，TLSA 可认证提交服务器及 MTA 间 TLS 连接，并声明必须使用加密，抵御降级。对于 S/MIME，格式相似的 SMIMEA 记录把证书与邮件地址所属域关联起来。

8. 学习目标 8：SPF 的机制与作用

SPF 让发送域在 DNS TXT 资源记录中公布策略，声明哪些主机或 IP 地址有权在 SMTP `MAIL FROM` 或 `HELO` 身份中使用该域。接收方检查实际发送 IP 与信封域的 SPF 记录，可在接收正文前拒绝未授权来源。

SPF 检查的是 SMTP 连接中的信封身份，不是 RFC 5322 消息头部中用户看到的 `From`。二者可以不同，这也是 SPF 不能独立解决可见发送方欺骗的原因。

机制	含义
`ip4` / `ip6`	指定授权 IPv4/IPv6 地址或地址范围。
`mx`	声明域的 MX 记录所列主机也是授权发送方。
`include`	递归引用其他域的 SPF 策略。
`all`	匹配此前未匹配的所有地址。

修饰符	结果含义
`+`	通过；未显式标注时的默认修饰符。
`-`	不允许该来源代表域发送邮件。
`~`	软失败，接收但标记并仔细检查。
`?`	中性，记录未对该机制表态。

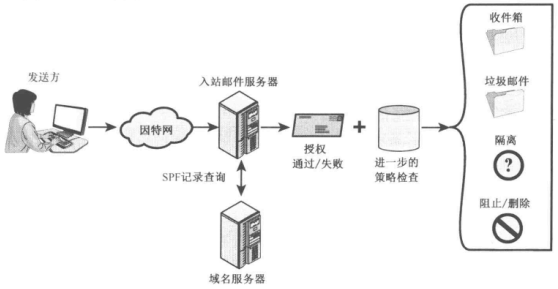


图 19.7　SPF 操作

图 19.7 接收端 SPF 检查过程

教材给出的接收规则是：查不到 SPF TXT 记录或记录格式出错时默认接收；其余情况按机制和修饰符决定处理。SPF 结果还需要与消息过滤、信誉判断和 DMARC 对齐结合。

9. 学习目标 9：DKIM 的机制与作用

DKIM 是域级邮件签名机制。签名 ADMD 内的授权模块使用域私钥，对消息正文和选定的 RFC 5322 头部签名；验证 ADMD 从 DNS 获取相应公钥，验证后结合签名域信誉和本地过滤策略处理邮件。DKIM 通常由 MUA、MSA 或 MTA 实现，对终端用户透明。

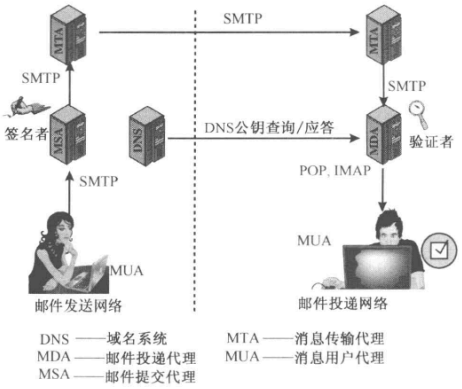


图 19.8　DKIM 操作的一个简单例子

图 19.8 DKIM 操作示例

DKIM 与 S/MIME 的边界不同：S/MIME 以用户密钥保护消息内容并要求通信双方采用相应客户端；DKIM 以管理域密钥保护该域发出的全部邮件，并可覆盖发送方相关头部。

签名前，DKIM 对头部和正文分别执行 `simple` 或 `relaxed` 规范化，以减少空格、折叠和编码等正常变换造成的验证失败。`DKIM-Signature` 的关键标记如下：

标记	含义
`v`	DKIM 版本。
`a`	签名算法，如 `rsa-sha256`。
`c`	头部/正文规范化算法。
`d`	签名域标识符（SDID）。
`s`	密钥选择器，用于在 DNS 中定位正确公钥。
`h`	被签名的头部字段列表。
`bh`	规范化后正文的哈希值。
`b`	base64 格式的签名数据。

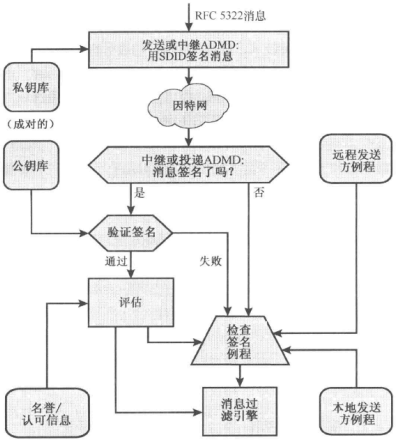


图 19.9 DKIM 功能流程

图 19.9 DKIM 功能流程

DKIM 可以证明持有某域私钥的一方对邮件负责并检测被签名内容的修改，但它不自动说明可见 `From` 域是否与签名域一致，也不能阻止拥有合法签名域的恶意发送者，因此还需 DMARC 对齐与信誉评估。

10. 学习目标 10：DMARC 的机制与作用

DMARC 结合 SPF 和 DKIM，规定如何认证用户可见的 RFC 5322 `From` 域、如何处置认证失败邮件，以及如何向发送域反馈部署效果。

三种身份对象必须明确区分：

协议	认证对象
SPF	SMTP 信封中的 MAIL FROM 或 HELO 域与发送 IP。
DKIM	DKIM-Signature 中 d= 指定的签名域及被签名内容。
DMARC	用户可见的 RFC 5322 `From` 域，并要求它与 SPF 或 DKIM 的认证域对齐。

10.1 策略和标识符对齐

DMARC 策略以 DNS TXT 记录发布，使用分号分隔的 `tag=value` 对。

标记	作用
v	版本，必须作为第一个元素。
p	主策略：none、quarantine 或 reject。
aspf / adkim	SPF/DKIM 对齐方式：r 为宽松，s 为严格。
rua / ruf	汇总报告和鉴定报告的接收 URI。
ri	期望的汇总报告间隔，默认 86400 秒。
fo	触发失败报告的条件。
pct	应用策略的邮件百分比，默认 100。
sp	子域策略。

宽松对齐允许认证域与 `From` 域属于同一组织域；严格对齐要求精确匹配。`p=none` 用于监控，`p=quarantine` 建议隔离可疑邮件，`p=reject` 建议拒绝未通过的邮件。发送方可先收集报告，再逐步提高策略强度。

10.2 接收处理与报告

接收端流程可概括为：基础黑名单/信誉检查；提取并验证唯一的 `From`；查询 DMARC；验证至少一个 DKIM 签名；执行 SPF；检查身份对齐；取得适用策略；形成 DMARC 通过/失败结论；按本地策略投递、隔离或拒绝，并收集报告数据。

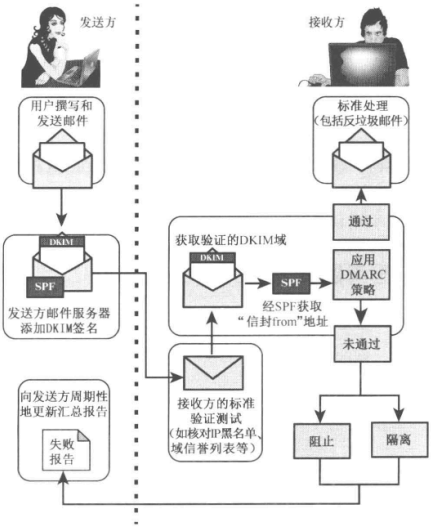


图 19.10　DMARC 功能流程

图 19.10 DMARC 功能流程

DMARC 提供两类反馈：

- **汇总报告**：周期性统计策略、投递/隔离/拒绝结果、SPF/DKIM 结果、对齐、子域、域对、认证成功数和消息总数，用于评估整体部署效果。
- **鉴定报告**：针对具体失败消息提供足够的头部、身份对齐、投递结果以及 DKIM 域和选择器等信息，帮助修复 SPF/DKIM 配置并发现域名被用于钓鱼或垃圾邮件。

本章关键术语整理

术语	核心含义
MUA	代表用户生成、提交、接收和显示邮件的消息用户代理。
MSA	接收邮件提交并执行托管域策略的邮件提交代理。
MTA	评估路由并在邮件系统中中继消息的传输代理。
MDA	将消息从 MHS 投递到消息存储的代理。
SMTP	通过 TCP 提交、中继和传输邮件的文本协议。
POP3	从服务器下载、检索和删除邮件的访问协议。
IMAP	访问并管理服务器端邮件的协议。
RFC 5322	定义因特网文本消息头部和正文格式的标准。
MIME	为邮件定义多媒体内容类型、传输编码和规范格式的扩展。

术语	核心含义
S/MIME	使用 CMS 对 MIME 实体签名、加密和压缩的端到端安全格式。
STARTTLS	将现有 SMTP 连接升级到 TLS 的扩展。
DNSSEC	用数字签名保护 DNS 数据源认证和完整性的扩展。
DANE	使用 DNSSEC 将证书或公钥与域名绑定的机制。
TLSA	DANE 用于描述证书用途、选择器和匹配方式的资源记录。
SPF	用 DNS 声明域授权发送主机并认证 SMTP 信封身份的框架。
DKIM	由管理域签名邮件正文和选定头部的域级认证机制。
DMARC	对齐可见 From 域与 SPF/DKIM 身份并发布处置及报告策略的协议。

学习目标自检

1. 能否画出 MUA、MSA、MTA、MDA、MS 的邮件路径，并说明 DNS 和 ADMD 的作用？
2. 能否区分 SMTP/ESMTP/SUBMISSION 与 POP3、IMAP 的方向、功能和端口？
3. 能否解释原始 SMTP/RFC 5322 为什么不能可靠支持二进制、多语言和多媒体邮件？
4. 能否列出 MIME 五个头部字段、七类内容、常见 multipart/message 子类型及六种传输编码？
5. 能否描述 S/MIME 的数字签名、混合加密、压缩、邮件兼容性、内容类型和证书处理？
6. 能否说明 STARTTLS 的升级过程、逐跳保护边界、降级攻击和证书验证问题？
7. 能否解释 DNSSEC 的四类安全资源记录、信任链和 TLSA 四种证书用途？
8. 能否根据发送 IP、SMTP 信封域、SPF 机制和修饰符判断授权结果？
9. 能否说明 DKIM 的签名位置、规范化、关键标记、DNS 公钥查询及与 S/MIME 的区别？
10. 能否区分 SPF、DKIM、DMARC 的认证对象，并说明 DMARC 对齐、策略、接收流程和两类报告？